

Plan de gestion des incidents de sécurité (Incident Response Plan)

1. Objectif

Définir les processus permettant de détecter, analyser, contenir, éradiquer et notifier tout incident de sécurité affectant la plateforme, afin de limiter les impacts opérationnels, juridiques et réputationnels.

2. Périmètre

Ce plan s'applique à : - Infrastructures IT - Applications web et mobiles - Bases de données - API et intégrations - Systèmes IA - Données personnelles et sensibles

3. Définition d'un incident de sécurité

Un incident est tout événement pouvant compromettre : - La confidentialité - L'intégrité - La disponibilité - La traçabilité

4. Typologie des incidents

- Accès non autorisé
- Fuite de données
- Malware / ransomware
- DDoS
- Altération de données
- Compromission de comptes
- Défaillance de contrôles de sécurité

5. Organisation et rôles

- Responsable incident (Incident Manager)
- Équipe sécurité
- Équipe IT
- Direction
- Communication
- Juridique / conformité

6. Cycle de gestion des incidents

6.1 Détection

- Alertes SIEM
- Signalement utilisateur
- Supervision automatique

6.2 Qualification

- Classification (critique, majeur, mineur)
- Évaluation de l'impact

6.3 Confinement

- Isolement des systèmes
- Suspension des comptes compromis

6.4 Éradication

- Suppression du malware
- Correction des vulnérabilités

6.5 Restauration

- Restauration depuis sauvegardes
- Vérification intégrité

6.6 Retour d'expérience

- Analyse post-incident
- Actions correctives

7. Notification et obligations

- Notification interne immédiate
- Notification aux autorités compétentes selon la loi
- Notification aux personnes concernées si données personnelles

8. Conservation des preuves

- Collecte sécurisée
- Chaîne de custody
- Conservation pour enquête

9. Communication de crise

- Messages internes
- Messages aux partenaires
- Messages publics si requis

10. Tests et formation

- Exercices annuels
- Sensibilisation équipes

11. Conformité et références

- ISO/IEC 27035 (Incident Management)
- NIST SP 800-61 (Computer Security Incident Handling Guide)

- ISO/IEC 27001

12. Mise à jour

- Revue annuelle
- Mise à jour après chaque incident majeur

Document de référence interne – Gestion des incidents de sécurité pour la plateforme de gestion numérique des auto-écoles et examens.